Hands-On Identity Operations in Microsoft Entra ID

Identity Hygiene · RBAC v2 · Enterprise Applications · Joiner/Mover/Leaver · Access Review · Conditional Access Design · Tenant Hardening · Non-Human Identities

Project Name	Healthcare IAM Operations Simulation
Organization	Horizon Valley Medical Center (HVMC)
Environment	Microsoft Entra ID tenant (Free tier), 33 accounts; changes made with Microsoft Graph via scripted, ticketed changes
Date	20 October 2026 (Step 7: 28 Oct; Step 8: 29 Oct 2026)
Document Version	1.2
Prepared By	Sabitha S Karanavar
Cost	$0 — every change used Entra ID Free features

1. Purpose and approach

The Week 1 design (scenario, RBAC matrix, OU structure and group naming) was turned into a working, governed identity environment. Every change followed the same controlled pattern: **a script shows a dry run, the change is approved, then applied under a change ticket, and before/after evidence is saved**. Group membership is the single source of truth: application access is derived from groups, so access always follows the approved design.

Step	Work	Ticket	Result
1	Identity hygiene — managers, employee IDs, contractor attributes, disable shared test account	HVMC-IAM-CHG-101	53 changes
2	RBAC v2 — groups that grant exactly the RBAC matrix	HVMC-IAM-CHG-102	13 groups, 45 memberships
3	Simulated enterprise applications with app roles	HVMC-IAM-CHG-103	10 apps, 75 assignments
4	Joiner, mover and leaver	HVMC-JML-201/202/203	3 lifecycle events + 1 finding fixed
5	Quarterly access review	HVMC-AR-2026-Q4	94 lines reviewed, 1 removal
6	Conditional Access design (report-only, licence-gated)	—	13 policies, 13 test cases
7	Free tenant hardening — consent, guests, self-service; break-glass administrators	HVMC-IAM-CHG-106/107	8 settings, Global Admins 1 → 3
8	Non-human identity with certificate credential and least-privilege Graph permission	HVMC-IAM-CHG-108	1 NHI, 3/3 least-privilege tests passed

2. Starting baseline (findings)

#	Finding	Why it mattered	Fixed in
F1	No user had a manager	Access reviews and lifecycle approvals need an accountable manager	Step 1
F2	No employee IDs	No link between an account and an HR record (risk R06)	Step 1

F3	One group per department	Secondary access in the RBAC matrix (e.g. doctors reading Pharmacy and LIS) was not grantable	Step 2
F4	Shared test account “Test Nurse - EHR” enabled	Shared account with ePHI access (risk R07)	Steps 1 and 5
F5	Contractor without type, sponsor or end date	Contractor access outlives the contract (risk R06)	Steps 1 and 4
F6	Single Global Administrator	No backup or emergency access (risk R04)	Step 7
F7	Permissive tenant defaults: user app consent, anyone can invite guests	Consent phishing and uncontrolled external access (risk R08)	Step 7
F8	No governed pattern for non-human (workload) identities	Service accounts with shared passwords or broad API permissions are a common breach path	Step 8

3. Step 1 — Identity hygiene

Each department lead became the manager of the department; every staff member received an immutable employee ID (`HVMC-<department code><sequence>`); the contractor was typed, sponsored and given an end date; the shared test account was disabled. The administrator's own account was excluded from automated changes.

Department	Manager (lead)	Reports	Employee IDs
Doctors	**Sarah Chen**	Aisha Rahman, James Okafor, Maria Gonzalez, Peter Novak	HVMC-1001 – HVMC-1005
Nursing	**Angela Brooks**	Emily Carter, Lisa Tran, Monica Alvarez, Noah Fischer, Robert Kim, Tyrone Jackson	HVMC-1101 – HVMC-1107
Pharmacy	**David Patel**	Marcus Webb, Nicole Reyes	HVMC-1201 – HVMC-1203
Laboratory	**Elena Petrova**	Priya Nair, Thomas Wright	HVMC-1301 – HVMC-1303
Human Resources	**Daniel Osei**	Karen Smith	HVMC-1401 – HVMC-1402
Finance	**Brian Adeyemi**	Michael Torres	HVMC-1501 – HVMC-1502
IT	**Kevin O'Brien**	Fatima Ali, Jason Park	HVMC-1601 – HVMC-1603
Security	**Denise Coleman**	Anthony Ruiz	HVMC-1701 – HVMC-1702
Reception	**Grace Nguyen**	Victor Mensah	HVMC-1801 – HVMC-1802

Measure	Before	After
Users with a manager	0	21
Users with an employee ID	0	30
Contractor with type, sponsor and end date	0	1
Shared test account enabled	1	0

Contractor Carlos Diaz: employee ID HVMC-C001, type Contractor, sponsor Kevin O'Brien, contract end 31 Dec 2026 (stored in employeeLeaveDateTime).

4. Step 2 — RBAC v2

New groups follow the Week 1 convention `SG-<Department>-<Application>-<Access>`, one per entitlement in the matrix. A coverage check compares every user's groups with the matrix for their department.

Measure	Before	After
Users whose groups exactly match the RBAC matrix	2/30	30/30
Missing entitlements	45	0
Access beyond the matrix	0	0
SG-* security groups	10	23

New groups: SG-Doctors-Pharmacy-Read, SG-Doctors-LIS-Read, SG-Nursing-Pharmacy-Read, SG-Nursing-LIS-Read, SG-Pharmacy-EHR-Read, SG-Lab-EHR-Read, SG-HR-Payroll-RW, SG-Finance-HRPortal-Read, SG-Finance-FinanceERP-RW, SG-IT-Scheduling-Admin, SG-IT-VPN-Read, SG-Reception-EHR-Read, SG-Contractors-ITAdmin-Limited.

Design decisions (RBAC v2 improves on the Week 1 matrix)

Entitlement held back	Decision and reason
SG-Contractors-EHR-Limited	No Business Associate Agreement on file for the contractor (risk R06) - ePHI access held until signed.
SG-IT-EHR-Read	D1 least privilege / HIPAA minimum necessary: IT staff get no standing ePHI access; break-fix access to be just-in-time.
SG-IT-Pharmacy-Read	D1 least privilege / HIPAA minimum necessary: no standing ePHI access for IT.
SG-IT-LIS-Read	D1 least privilege / HIPAA minimum necessary: no standing ePHI access for IT.
SG-IT-SecurityPortal-Admin	D2 separation of duties: only the Security team administers security monitoring of IT's own actions.

5. Step 3 — Simulated enterprise applications

Each business application from the Week 1 list exists as an app registration and enterprise application with **app roles** for its access levels, **assignment required** (unassigned users are refused), **no secrets or API permissions**, and a homepage on the reserved `.example` domain. Entra ID Free cannot assign *groups* to applications, so a sync script derives *user* assignments from group membership — adding missing ones and removing stale ones — which keeps groups the single source of truth.

Application	App roles	Assignment required	Users
HVMC Electronic Health Record	Read, ReadWrite	Yes	20
HVMC Pharmacy Management System	Read, ReadWrite	Yes	15
HVMC Laboratory Information System	Read, ReadWrite	Yes	15
HVMC HR Portal	Read, ReadWrite	Yes	4
HVMC Payroll System	ReadWrite	Yes	4
HVMC Finance ERP	ReadWrite	Yes	2
HVMC IT Administration Console	Limited, Admin	Yes	4
HVMC Security Monitoring Portal	Admin	Yes	2
HVMC Appointment Scheduling	ReadWrite, Admin	Yes	5
HVMC VPN Portal	Read	Yes	4

6. Step 4 — Joiner, mover, leaver

Group membership is derived from the RBAC v2 matrix; the application sync then follows automatically.

Ticket	Event	Groups before	Groups after	Apps before	Apps after	Account
HVMC-JML-201 Joiner	New hire: Olivia Bennett, Registered Nurse, starts 2026-10-21	—	SG-Nursing-EHR-RW, SG-Nursing-LIS-Read, SG-Nursing-Pharmacy-Read	—	Electronic Health Record, Laboratory Information System, Pharmacy Management System	Enabled
HVMC-JML-202 Mover	Transfer: Noah Fischer, Nursing -> Pharmacy as Pharmacy Technician	SG-Nursing-EHR-RW, SG-Nursing-LIS-Read, SG-Nursing-Pharmacy-Read	SG-Pharmacy-EHR-Read, SG-Pharmacy-PharmacySystem-RW	EHR-Simulated, Electronic Health Record, Laboratory Information System, Pharmacy Management System	EHR-Simulated, Electronic Health Record, Pharmacy Management System	Enabled
HVMC-JML-203 Leaver	Termination: contractor Carlos Diaz, engagement ended early (sponsor Kevin O'Brien)	SG-Contractors-ITAdmin-Limited, SG-Contractors-VPN-Read	—	IT Administration Console, VPN Portal	—	**Disabled**

> **Finding F-JML-01:** F-JML-01 legacy app EHR-Simulated (created 2026-10-12, direct user assignments, not group-driven) kept nurse EHR access after the transfer. **Action:** removed 1 EHR-Simulated assignment(s) for Noah Fischer. The joiner's initial password was random, never displayed or stored, with a forced change at first sign-in; the leaver was disabled and all sign-in sessions revoked before groups were removed, and the account kept (disabled) for audit.

7. Step 5 — Access review HVMC-AR-2026-Q4

Scope: every SG-* membership (which drives application access), direct application assignments, directory roles, Azure RBAC roles and disabled accounts. Reviewers: each user's manager; privileged roles and workload identities: the Security Supervisor; department leads and admin/test accounts: the IAM administrator. HIPAA 45 CFR 164.308(a)(3)(ii)(B)–(C) and (a)(4)(ii)(C).

94	93	1	10
review lines	kept with justification	removed	reviewers

Flag	Lines
None (matches RBAC v2)	75
LEGACY / DIRECT	11
WORKLOAD IDENTITY	5
PRIVILEGED	1
PRIVILEGED - SOLE HOLDER	1
DISABLED ACCOUNT	1

Finding	Decision
Disabled shared test account still held Azure role HVMC-Nurse-EHR-ReadOnly on the ePHI storage account — disabling an account does not remove its roles	Removed (reviewer: Security Supervisor)
Legacy app EHR-Simulated (created 12 Oct) assigned per user, outside group control	Brought under group-driven sync from SG-Doctors-EHR-RW and SG-Nursing-EHR-RW; existing assignments kept for continuity of earlier evidence
Single Global Administrator	Kept; action: two break-glass accounts (done in Step 7)
Microsoft service identities created by Defender/Sentinel onboarding	Kept (platform-managed)

Actions log: Test Nurse - EHR HVMC-Nurse-EHR-ReadOnly on hvmcehrstorage → ok; group-driven app sync (incl. EHR-Simulated) → 1/1 changes applied..

8. Step 6 — Conditional Access design

The tenant runs **security defaults** (confirmed by an AADSTS530035 block on 14 Oct 2026). Conditional Access needs Entra ID P1 (risk policies P2), so the policy set was designed and generated as deployable Microsoft Graph files in report-only state; the deployment script refuses to run without a licence. Full detail: *HVMC_Conditional_Access_Design.pdf*.

ID	Policy	Persona	Licence	Risks
CA001	Global-AllApps-BlockLegacyAuthentication	Everyone	P1	R12
CA002	Admins-AllApps-RequirePhishingResistantMFA	Administrators	P1	R04, R12
CA003	Global-AllApps-RequireMFA	Everyone	P1	R12, R06
CA004	Global-AzureManagement-RequireMFA	Everyone	P1	R02, R15
CA005	Global-ePHIApps-RequireMFAandManagedDevice	Clinical users (EHR, Pharmacy, LIS)	P1 + Intune	R02, R13
CA006	Global-ePHIApps-NoPersistentBrowserOnUnmanaged	Everyone on unmanaged devices	P1	R02
CA007	Contractors-AllExceptAssigned-Block	Contractors	P1	R06
CA008	Contractors-AllApps-MFAEverySession	Contractors	P1	R06
CA009	Global-AllApps-BlockOutsideAllowedCountries	Everyone	P1	R12
CA010	Global-AllApps-BlockDeviceCodeAndAuthTransfer	Everyone	P1	R12
CA011	Global-SecurityInfoRegistration-RequireUSLocationOrMFA	Everyone	P1	R12
CA012	Global-AllApps-HighUserRisk-SecurePasswordChange	Everyone	P2	R12
CA013	Global-AllApps-MediumHighSignInRisk-RequireMFA	Everyone	P2	R12

Rollout: P2 trial → break-glass accounts and US named location → 14 days report-only → IT pilot → everyone (security defaults off) → clinical device policies and risk-based policies. Licence needs: P1: 10 policies; P1 + Intune: 1 policies; P2: 2 policies.

9. Step 7 — Free tenant hardening

Two open risks from the baseline and the access review were closed with free Entra ID settings, using the same dry-run → approval → apply → before/after evidence pattern (`step7_tenant_hardening/tenant_hardening.py`).

Part A — Tenant settings (HVMC-IAM-CHG-106, risk R08)

Users could consent to applications themselves — the route used by **consent-phishing** attacks, where a fake app asks a user for access to mail or files — register apps, create tenants and groups outside the IAM process, and anyone (even guests) could invite guests. All of these now go through administrators. The settings were re-read from the tenant after the change to confirm them.

Setting	Before	After
Who can invite guests	Everyone, including guests	**Admins and Guest Inviter role only**
Guest directory access	limited (default)	**restricted to own object**
Email-verified self-service sign-up	Yes	**No**
Self-service sign-up for subscriptions	Yes	**No**
Users can register applications	Yes	**No**
Users can create security groups	Yes	**No**
Users can create tenants	Yes	**No**
User consent to applications	Allowed (4 consent policies)	**Do not allow user consent**

Part B — Emergency-access (break-glass) accounts (HVMC-IAM-CHG-107, risk R04)

The tenant had a single Global Administrator: a lost phone, a forgotten password or a locked account would have left nobody able to administer HVMC's identities. Microsoft recommends two cloud-only emergency-access accounts. Rather than making a staff member a permanent Global Administrator — which would break the least-privilege decision D2 — two dedicated accounts were created.

Global Administrator	Account
Named administrator	IAM administrator (Sabitha S Karanavar)
Emergency Access	bg-admin-01@<tenant>.onmicrosoft.com
Emergency Access	bg-admin-02@<tenant>.onmicrosoft.com

Control	Implementation
Cloud-only, on the .onmicrosoft.com domain	No dependency on a custom domain, federation or on-premises sync
Strong secret, never displayed	40-character random passwords (~250 bits), written only to a local file readable by the owner; transferred to a password manager / sealed envelope, then the file deleted
No daily use, no other access	No licence, no SG-* groups, no application access; job title marks them as emergency-only
MFA	Security defaults remain on, so each account registers MFA at first sign-in (on a separate authenticator)

Testing and monitoring	Sign-in test every quarter; sign-in logs reviewed after each use (Free tier keeps 7 days of sign-in logs)

10. Step 8 — Non-human identities

Hospital systems talk to each other without a person signing in: an interface engine, a lab system, a backup job. These **non-human identities (NHIs)** often outnumber people and are a common breach path when they use shared passwords, never-expiring secrets or broad permissions. Step 8 inventoried HVMC's NHIs and created the first one using the secure pattern (`step8_nonhuman_identities/nhi.py`, change HVMC-IAM-CHG-108).

Baseline inventory (read-only)

Category	Count	Assessment
User accounts used as service accounts	0	None — matches Microsoft guidance to use workload identities instead
HVMC application service principals	11	No secrets, certificates or API permissions — cannot authenticate on their own
Managed identities	2	Created by Defender for Storage (SecOps lab); probably orphaned since the subscription was disabled — noted for HVMC-AR-2027-Q1
Microsoft / third-party service principals	123	Present in every tenant; no action

The new NHI: HVMC Lab Results Sync

Control	Implementation
Purpose and ownership	Read members of the laboratory groups for the lab results interface. Technical owner: IAM administrator (Sabitha S Karanavar); business owner: Laboratory lead (Daniel Osei)
Identity type	Single-tenant application service principal, tagged HVMC-NHI, ticket in its notes
Credential	X.509 certificate (RSA-2048) issued by **HVMC Issuing CA 1** from the project's own PKI; **no client secret**. Private key kept locally (mode 0600, not in Git), to move into Azure Key Vault
Lifetime	Expires 2027-10-29; rotate by 2027-09-29
Permission	Microsoft Graph **GroupMember.Read.All** (application) only, granted by admin consent
Review	Recorded in the NHI register; reviewed in HVMC-AR-2027-Q1

The NHI then signed in **as itself, with its certificate** (OAuth 2.0 client credentials with a signed JWT assertion). Its token carried exactly one permission (`GroupMember.Read.All`) and the identity type "application". Three calls proved least privilege:

Call made by the NHI	Expected	Result
read members of SG-Lab-LIS-RW	200	HTTP 200 3 members — **PASS**
list all users in the directory	403	HTTP 403 Authorization_RequestDenied — **PASS**
change the description of SG-Lab-LIS-RW	403	HTTP 403 Authorization_RequestDenied — **PASS**

Next for NHIs: move the private key into Azure Key Vault and use a managed identity (instructor-approved, needs an active subscription); a GitHub Actions identity with a federated credential (no secret at all); Workload ID Premium controls (Conditional Access and risk detection for workload identities) documented as a licensed design.

11. Results, lessons learned and next steps

Outcome	Evidence
Every active staff member's access matches the approved RBAC v2 design (30/30), with no excess access	Step 2 coverage check, re-run after Steps 4–5
Application access is group-driven and self-correcting, including the legacy EHR app	Step 3 sync: 0 additions / 0 removals pending
Joiners, movers and leavers are repeatable, ticketed and evidenced	HVMC-JML-201/202/203 evidence files
Quarterly access review produced decisions, justifications and a removal	HVMC-AR-2026-Q4 decided review pack (Excel)
Zero Trust sign-in policy ready to deploy when licensed	13 report-only policy files + 13 test cases
Tenant defaults hardened and the single-admin risk removed (R04, R08 closed)	Step 7 before/after policy evidence; 3 Global Administrators
First non-human identity built secret-less and proven least-privilege	Step 8 certificate sign-in: 1 allowed call, 2 denied calls

Lessons learned

- **Disabling is not deprovisioning:** a disabled account kept an Azure data role until the access review removed it.
- **Unmanaged apps defeat good group design:** a direct-assigned legacy app kept a transferred nurse's EHR access (F-JML-01).
- **Licences shape the design:** on the Free tier, group-to-app assignment and Conditional Access are unavailable, so automation and documented design fill the gap until a licence is justified.
- **Non-human identities need owners and expiry dates:** a certificate with a rotate-by date and a named owner is reviewable; a forgotten secret is not.
- **Least privilege needs judgement:** following the Week 1 matrix literally would have given IT standing ePHI access; RBAC v2 records why it does not.

Next steps

Action	Cost	Risk
Quarterly break-glass sign-in test (next about 28 Jan 2027)	$0	R04
Azure Key Vault for the NHI private key, plus a managed identity (instructor-approved)	Needs an active subscription	NHI
Start the 30-day P2 trial; deploy the 13 policies in report-only; then PIM and native access reviews	$0 (trial)	R04, R12
Domain controller hvmc-dc01 (HVMC.LAN) is built: join client HVMC-CLIENT01 and mirror the 31 identities by script	$0	—

Appendix — change register and files

Ticket	Date	Description
HVMC-IAM-CHG-101	20 Oct 2026	Identity hygiene, 53 attribute/manager/account changes
HVMC-IAM-CHG-102	20 Oct 2026	RBAC v2, 59 group/membership/description changes
HVMC-IAM-CHG-103	20 Oct 2026	Enterprise applications, 85 app/assignment changes

HVMC-JML-201/202/203	20 Oct 2026	Joiner Olivia Bennett, mover Noah Fischer, leaver Carlos Diaz
HVMC-AR-2026-Q4	20 Oct 2026	Access review: 94 lines, 1 removal, legacy app brought under management
HVMC-IAM-CHG-106	28 Oct 2026	Tenant settings: user consent, app registration, tenant and group creation, guest invitations and access, self-service sign-up
HVMC-IAM-CHG-107	28 Oct 2026	Two emergency-access (break-glass) Global Administrator accounts
HVMC-IAM-CHG-108	29 Oct 2026	Non-human identity HVMC Lab Results Sync: certificate credential, GroupMember.Read.All, least-privilege test

Scripts: step1_identity_hygiene/identity_hygiene.py · step2_rbac_v2/rbac_v2.py · step3_enterprise_apps/enterprise_apps.py · step4_jml/jml.py · step5_access_review/build_review_pack.py, apply_decisions.py · step6_conditional_access/ca_design.py, deploy_ca.py · step7_tenant_hardening/tenant_hardening.py · step8_nonhuman_identities/nhi.py. Each runs as a dry run by default and changes nothing without --apply.